

Migration des logs de sécurité Splunk → Google Chronicle

Collecte Unix / Windows via Amazon CloudWatch, collecte AIX via rsyslog, et archivage légal centralisé sur Amazon S3.

Document : Note d'architecture

Date : 14 septembre 2026

Version : 1.0

1. Contexte et objectifs

L'organisation souhaite faire évoluer sa chaîne de collecte et d'analyse des logs de sécurité en remplaçant progressivement **Splunk** par **Google Chronicle (Google Security Operations)** comme plateforme SIEM cible, tout en garantissant :

- une **collecte homogène** des logs de sécurité sur l'ensemble du parc (Unix/Linux, Windows, AIX) ;
- un **archivage légal et immuable** des logs bruts sur Amazon S3, indépendant du SIEM utilisé ;
- une bascule **progressive et réversible** depuis Splunk, sans rupture de la capacité de détection ;
- une prise en compte des contraintes spécifiques d'**AIX**, qui ne dispose pas d'agent CloudWatch ni d'agent SSM officiellement supporté par AWS.

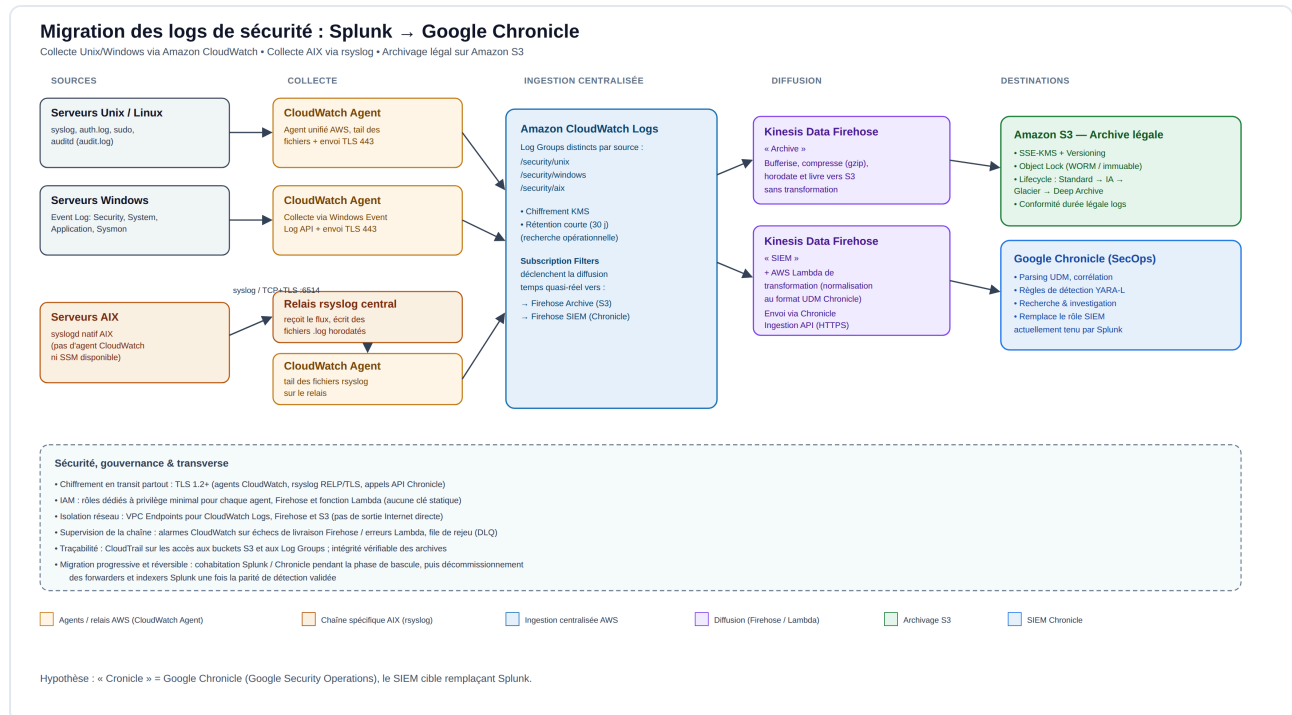
Hypothèse de lecture : le document part du principe que « Cronicle » désigne **Google Chronicle** (Google Security Operations), la plateforme SIEM cible qui remplace Splunk. Cronicle (le scheduler de tâches open-source) n'a pas de fonction SIEM et n'est pas retenu dans cette architecture ; si un autre outil était visé, la partie « SIEM cible » de ce document (section 3.5) est la seule à ajuster.

Principes directeurs

- **Un seul chemin de collecte technique** par OS, qui alimente à la fois l'archivage et le SIEM (pas de double agent Splunk + Chronicle sur les serveurs) ;
- **Découplage archivage / analyse** : l'archive S3 ne dépend d'aucun SIEM et reste exploitable même en cas de changement futur d'outil d'analyse ;
- **Sécurité par construction** : chiffrement de bout en bout, moindre privilège, traçabilité des accès.

2. Vue d'ensemble de l'architecture

Le schéma ci-dessous présente le flux complet, des sources de logs jusqu'à l'archivage S3 et l'ingestion dans Chronicle.



Légende : orange = agents CloudWatch ; ambre = chaîne spécifique AIX (rsyslog) ; bleu = ingestion centralisée AWS ; violet = diffusion (Firehose/Lambda) ; vert = archivage S3 ; bleu Google = SIEM Chronicle.

Logique générale

- Chaque famille de serveurs (Unix/Linux, Windows, AIX) est instrumentée avec le mécanisme de collecte le plus adapté à son OS.
- Tous les flux convergent vers **Amazon CloudWatch Logs**, qui devient le point de collecte centralisé unique, quel que soit l'OS source.
- Depuis CloudWatch Logs, deux *Subscription Filters* diffusent chaque évènement en parallèle, sans duplication de la collecte à la source :
 - un flux « **Archive** » vers Amazon S3, sans transformation, pour la conservation légale ;
 - un flux « **SIEM** », transformé au format UDM (Unified Data Model) puis poussé vers Chronicle pour la détection et l'investigation.

3. Détail des composants

3.1 Collecte Unix / Linux

Sur chaque serveur Unix/Linux, l'**agent unifié Amazon CloudWatch** (CloudWatch Agent) est déployé et configuré pour suivre (tail) les fichiers de logs de sécurité pertinents :

- /var/log/syslog ou /var/log/messages ;
- /var/log/auth.log ou /var/log/secure (authentications, sudo, SSH) ;
- /var/log/audit/audit.log (auditd) pour les événements d'audit noyau.

L'agent envoie les événements en TLS vers un *Log Group* CloudWatch dédié (/security/unix/<hostname>), avec le nom d'hôte et l'horodatage d'origine préservés.

3.2 Collecte Windows

Sur les serveurs Windows, le même **CloudWatch Agent** est utilisé, configuré pour lire les journaux d'évènements Windows via l'API Event Log :

- journal **Security** (connexions, élévations de privilèges, gestion des comptes) ;
- journaux **System** et **Application** ;
- journal **Sysmon** si déployé (recommandé pour la détection avancée).

Les événements sont envoyés vers /security/windows/<hostname>. Le déploiement de l'agent et de sa configuration peut être industrialisé via GPO / SCCM ou AWS Systems Manager (State Manager) selon l'outillage déjà en place.

3.3 Collecte AIX (cas particulier)

AIX ne disposant pas d'agent CloudWatch officiellement supporté, la collecte repose sur le **syslogd natif d'AIX**, qui transmet les événements de sécurité vers un **relais rsyslog central** mutualisé (une paire de serveurs Linux dédiés, en haute disponibilité) :

- transport en syslog over TCP, chiffré en TLS (RELP/TLS ou stunnel si la version d'AIX ne supporte pas nativement TLS), port dédié (ex. 6514) ;
- le relais rsyslog écrit les événements reçus dans des fichiers locaux, un fichier par host source et par jour, afin de conserver la traçabilité d'origine ;
- un **CloudWatch Agent** installé sur le relais lui-même effectue le tail de ces fichiers et les pousse vers /security/aix/<hostname>, rejoignant ainsi le même pipeline que les autres OS.

Pourquoi ce détour par rsyslog ? Il isole la contrainte technique AIX (absence de support CloudWatch natif) dans un composant unique et mutualisé, sans exiger de développement spécifique ni d'agent tiers sur chaque hôte AIX, tout en réintégrant le flux dans le pipeline commun dès que possible (au niveau du relais).

3.4 Ingestion centralisée — Amazon CloudWatch Logs

CloudWatch Logs constitue le point de convergence unique des trois filières de collecte. Chaque Log Group est :

- chiffré avec une clé **KMS** dédiée à la sécurité ;
- configuré avec une **rétenion courte** (ex. 30 jours), suffisante pour la recherche opérationnelle immédiate, la rétenion longue étant déléguée à S3 ;
- associé à des **Subscription Filters** qui diffusent chaque nouvel événement, en quasi temps réel, vers les flux Archive et SIEM décrits ci-dessous.

3.5 Diffusion — Kinesis Data Firehose

Flux	Rôle	Traitement	Destination
Firehose « Archive »	Conservation légale du log brut	Mise en tampon, compression gzip, découpage par date/heure	Amazon S3
Firehose « SIEM »	Alimentation de la détection	Transformation via AWS Lambda (normalisation au format UDM Chronicle)	Google Chronicle (Ingestion API)

Le flux SIEM peut, selon l'outillage retenu côté Google, être poussé directement via l'API d'ingestion Chronicle depuis Lambda, ou relayé par un **forwarder/BindPlane** hébergé sur AWS si un point d'entrée on-prem/agent est préféré à l'appel API direct.

3.6 Archivage — Amazon S3

Protection des données

- Chiffrement SSE-KMS
- Versioning activé
- **Object Lock** en mode Compliance (WORM) pour garantir l'immuabilité sur la durée légale

Optimisation des coûts

- Lifecycle : Standard → Standard-IA → Glacier → Deep Archive
- Organisation par préfixe :
s3://.../aix|unix|windows/AAAA/MM/JJ/host/

3.7 SIEM cible — Google Chronicle

Chronicle assure les fonctions auparavant portées par Splunk :

- normalisation des événements au format **UDM** ;
- corrélation et détection via des règles **YARA-L** ;
- recherche, investigation et retro-hunt sur l'historique ingéré.

4. Sécurité et conformité

- **Chiffrement en transit** systématique : TLS 1.2+ pour les agents CloudWatch, pour le flux rsyslog AIX (RELP/TLS ou tunnel stunnel), et pour les appels à l'API Chronicle.
- **Chiffrement au repos** : KMS sur les Log Groups CloudWatch et sur le bucket S3 d'archive.
- **IAM à moindre privilège** : un rôle dédié par agent/service (agents, Firehose, Lambda), sans clé d'accès statique, avec des rôles IAM assumés (instance profiles / rôles de service).
- **Isolation réseau** : VPC Endpoints pour CloudWatch Logs, Kinesis Firehose et S3, afin d'éviter toute sortie vers Internet pour le trafic interne AWS.
- **Immuabilité des archives** : Object Lock S3 en mode Compliance pour empêcher toute suppression ou modification pendant la durée de rétention légale.
- **Traçabilité** : CloudTrail activé sur les accès aux buckets S3 et aux Log Groups eux-mêmes (traçer qui consulte les logs de sécurité).
- **Supervision de la chaîne de collecte** : alarmes CloudWatch sur les échecs de livraison Firehose, les erreurs Lambda, et une file de rejeu (DLQ) pour ne perdre aucun événement en cas d'incident transitoire côté Chronicle.

5. Plan de migration par phases

Phase 0 — Cadrage

Inventaire des sources de logs actuellement indexées dans Splunk, cartographie par OS et par criticité, définition de la durée de rétention légale par type de log.

Phase 1 — Socle AWS

Mise en place des Log Groups CloudWatch, du bucket S3 (chiffrement, Object Lock, lifecycle), des rôles IAM et des VPC Endpoints.

Phase 2 — Collecte Unix & Windows

Déploiement du CloudWatch Agent sur un périmètre pilote, validation de la complétude des logs reçus par rapport à Splunk, puis généralisation au reste du parc.

Phase 3 — Collecte AIX

Mise en place du relais rsyslog central (haute disponibilité), configuration du syslogd AIX, puis du CloudWatch Agent sur le relais.

Phase 4 — Diffusion et archivage

Activation du Firehose « Archive » vers S3 ; validation de l'intégrité et de la conformité légale des archives produites.

Phase 5 — Bascule SIEM

Activation du Firehose « SIEM » + Lambda de transformation UDM vers Chronicle ; cohabitation Splunk / Chronicle le temps de valider la parité des règles de détection et des tableaux de bord.

Phase 6 — Décommissionnement Splunk

Une fois la parité de détection validée et la période de recouvrement contractuel écoulée, arrêt des forwarders et indexers Splunk restants.

6. Points d'attention et recommandations

- **Volumétrie** : dimensionner le débit du relais rsyslog AIX et des Firehose selon le pic d'événements/seconde observé côté Splunk (indexation actuelle), pour éviter tout throttling.
- **Haute disponibilité du relais AIX** : au moins deux instances actives/passives (ou load-balancées) pour ne pas créer de point de défaillance unique sur la seule filière sans agent natif AWS.
- **Cohérence des horodatages** : s'assurer que rsyslog et le CloudWatch Agent préservent le timestamp d'origine du serveur AIX (et non l'heure de réception sur le relais).
- **Tests de restitution** : valider régulièrement une restauration depuis S3 Glacier/Deep Archive afin de garantir l'exploitabilité réelle des archives en cas de besoin légal ou d'investigation.
- **Double run temporaire** : prévoir le coût et la durée de la cohabitation Splunk/Chronicle (licences, stockage) dans le budget de migration.
- **Format Chronicle** : valider tôt les parsers UDM disponibles nativement pour chaque type de log (syslog, Windows Event, auditd) afin de calibrer l'effort réel de la Lambda de transformation.